

Narrativa Explicativa de la Encuesta MITRE ATT&CK

1. Por qué una encuesta sobre MITRE ATT&CK

MITRE ATT&CK se ha convertido en la gramática común de las amenazas: describe cómo piensan y actúan los adversarios, táctica a táctica, técnica a técnica.[web:3][web:29][web:66]

Desde 2025 la conversación ha cambiado: no basta con decir “tenemos firewalls”; hay que poder afirmar “vemos y entendemos estas rutas de ataque y estas otras no tanto”. [web:16][web:22][web:64]

La encuesta pretende capturar precisamente eso: cuánto ha penetrado ATT&CK en la forma en que la organización diseña, opera y mide su defensa.

2. De la matriz en la pared a la métrica en el panel

Las evaluaciones MITRE ATT&CK Enterprise de 2025 han consolidado indicadores como:

- Cobertura de técnicas.
- Capacidad de protección.
- Tiempos de detección.
- Falsos positivos y calidad de las alertas.[web:16][web:22][web:60][web:64]

Simultáneamente, ENISA y las agencias europeas han aumentado el uso de ATT&CK para describir TTP en sus Threat Landscapes, especialmente en sectores como administración pública, OT e infraestructuras críticas.[web:66][web:43][web:61][web:63]

La encuesta nace en ese cruce: un lenguaje técnico común y una necesidad política y económica de medir.

3. Qué se quiere medir realmente

La encuesta se centra en tres grandes preguntas disfrazadas de muchas pequeñas:

1. ¿Qué tanto ve la organización?
2. Cobertura de tácticas y técnicas.
3. Profundidad de la detección: ¿sólo síntomas burdos o también señales sutiles?[web:16][web:22][web:26]
4. ¿Qué tan bien reacciona?
5. Tiempos de detección, contención y recuperación.
6. Uso de ATT&CK en los procesos de respuesta, aprendizaje y mejora.[web:26][web:66]
7. ¿Qué tanto se gobierna y se justifica?
8. Cómo ATT&CK influye en decisiones de inversión.
9. Cómo se traduce en KPIs, en informes a la dirección, en ROI.[web:29][web:50][web:53]

Profundidad de la detección: ¿sólo síntomas burdos o también señales sutiles?[web:16][web:22][web:26]

¿Qué tan bien reacciona?

Uso de ATT&CK en los procesos de respuesta, aprendizaje y mejora.[web:26][web:66]

¿Qué tanto se gobierna y se justifica?

4. Tono y espíritu

El tono de la encuesta es deliberadamente irónico, pero no cínico.

La ironía ayuda a admitir verdades incómodas:

- El SOC que sólo mira “lo que salta” y no lo que falta.
- El tablero de ATT&CK impoluto en la presentación, pero desalineado con la realidad del tráfico.

La intención es propositiva: hacer visibles las brechas para que puedan cerrarse, no para enumerar culpas.

5. Cómo leer las respuestas

La lectura recomendada:

- No obsesionarse con el número absoluto, sino con:
- Los bloques más débiles.
- Las incoherencias (por ejemplo, alta madurez en gobierno, pero sin métricas temporales mínimamente decentes).
- Identificar:
- Técnicas críticas del sector sin cobertura (por ejemplo, credenciales y movimiento lateral en entornos OT, o phishing y BEC en administración).[web:66][web:61][web:63]
- Dependencias excesivas de proveedores con buena nota MITRE, pero sin integración adecuada en procesos internos.[web:16][web:22][web:65]

6. Y después, ¿qué?

Idealmente, la encuesta se convierte en:

- Punto de partida de un plan de mejora con proyectos concretos:
- Incrementar cobertura en técnicas “rojas” del sector.
- Reducir MTTD y MTTC en cadenas de ataque frecuentes.[web:26][web:66]
- Base cuantitativa para:
- Comparación interanual.
- Benchmark interno entre unidades o países.
- Preparación de informes regulatorios o de consejo.

Si al final del ejercicio la organización pasa de “tenemos algo de ATT&CK” a “tenemos claros nuestros puntos ciegos y cómo atacarlos”, se habrá ganado la partida... o al menos la campaña.